

LA NARRATIVA OCULTA DE LA CIBERSEGURIDAD:

Prólogo Irónico, Literario y Propositivo para la Encuesta Integral IA

Un ensayo breve sobre por qué esta encuesta es, simultáneamente, necesaria, absurda y esperanzadora

PRELUDIO: EL TEATRO DE LA SEGURIDAD

Estimado director de ciberseguridad, estimada responsable de gobernanza IA, estimados actores todos en este teatro digital donde cada uno desempeña su papel:

Esta encuesta no llegará a ustedes como un árbitro despiadado que viene a contar cuánto **no han hecho** (que es lo que verdaderamente son muchas encuestas: listas de vergüenza disfrazadas de cuestionarios). Tampoco como aquella propuesta comercial con matices de investigación académica que promete revelar "los 7 secretos de los CISOs que ganaron" o "la única métrica que importa" (spoiler: no existe).

No. Esta encuesta llega con un propósito radical: **reconocer la complejidad legítima de lo que ustedes enfrentan, mientras simultáneamente les invita a la acción precisa y medida.**

ACTO I: CONFESIÓN SOBRE EL ABSURDO

La Verdad que Nadie Dice en Voz Alta

Escenario: Despacho ejecutivo. CISO sudando bajo corbata. Board pregunta: "¿Somos seguros?"

La respuesta honesta que el CISO nunca dará: "Señoras y señores, dependiendo de a quién le pregunto, cuánto dinero asigne, si el equipo almuerza bien ese día, el ciclo lunar y la cantidad de café en mi sistema, podremos hablar de 'seguridad'."

Pero en cambio, en ese mismo despacho, el CISO dirá algo como: "Implementamos controles NIST, pasamos auditoría ISO 27001, tenemos SLA en MTTRD..." Y todos asintirán, como si la seguridad fuera una fórmula donde suma de certificaciones = paz mental.

Bienvenida a la ilusión confortadora.

El Problema Fundamental

La ciberseguridad actual sufre de una paradoja kafkiana:

- Por un lado: Es más compleja que nunca. LLMs pueden ser envenenados con 250 muestras. Agentes autónomos operan sin supervisión humana continua. Supply chain compromiso es casi inevitable en escala. Regulaciones se solapan (AI Act + NIS2 + RGPD + AIDA = un Frankenstein legal).
- Por otro lado: Se mide con números que en realidad no significan nada sin contexto. "MTTD de 4 horas" suena bien hasta que la amenaza que tardó 4 horas en detectar ya había copió 50GB de datos en 2 horas. "Tasa de clics phishing del 8%" parece excelente hasta que ese 8% incluye al empleado que gestiona transferencias internacionales de €50 millones.

Por un lado: Es más compleja que nunca. LLMs pueden ser envenenados con 250 muestras. Agentes autónomos operan sin supervisión humana continua. Supply chain compromiso es casi inevitable en escala. Regulaciones se solapan (AI Act + NIS2 + RGPD + AIDA = un Frankenstein legal).

Por otro lado: Se mide con números que en realidad no significan nada sin contexto. "MTTD de 4 horas" suena bien hasta que la amenaza que tardó 4 horas en detectar ya había copió 50GB de datos en 2 horas. "Tasa de clics phishing del 8%" parece excelente hasta que ese 8% incluye al empleado que gestiona transferencias internacionales de €50 millones.

La ironía capital: Cuanta más data recolectamos sobre seguridad, menos comprensión real tenemos de si somos *realmente* seguros.

ACTO II: EL ESPEJO SIN COMPLACENCIA

Qué Esta Encuesta Realmente Es (Y No Es)

No es un examen de aprobado/suspense. No estamos aquí para darle una calificación de 6.5/10 que cierre expedientes de cumplimiento. La seguridad no funciona así. Ningún CISO que ha visto ransomware cifrar sus servidores cree en notas de corte.

No es un documento de marketing de consultoras. Este no es el documento que llegará a ustedes acompañado de propuesta comercial donde "lo encantador es que coincidentemente nuestros servicios resuelven exactamente sus gaps identificados." Aunque seguramente algunos lo reutilizarán así. Que así sea; que al menos la encuesta misma sea honesta.

No es una pluma de culpabilidad. Especialmente *no* quiere cargar sobre los CISOs de pequeñas empresas la afrenta moral de "no haber implementado SIEM empresarial." Porque la realidad es que ese CISO probablemente gestiona seguridad, cumplimiento, recuperación desastres, auditoría interna, y además atiende al correo porque no hay presupuesto para administrativo.

Lo Que Sí Es

Esta encuesta es un **espejo sin complacencia pero sin sadismo.**

Es una herramienta para que ustedes se vean reflejados en:

1.
Su realidad presente: No la que debería ser en algunos blog de gurus de ciberseguridad. Su realidad: presupuesto, equipo, restricciones, legados.
2.
Su posición relativa: Versus pares honestamente similares (no versus Google o Amazon). Benchmark significa "sé dónde estoy vs. alguien parecido a mí", no "confirme que me estoy quedando atrás."
3.
Sus oportunidades reales: No las que suena bien en PPT, sino aquellas con ROI medible a 12-24 meses.
4.
Sus fortalezas ignoradas: Porque la mayoría de PYMEs que respondieron hace 10 años a encuestas se asumía "inseguras por default". Muchas tienen prácticas brillantes a pesar de recursos limitados. Queremos documentar eso.

Su realidad presente: No la que debería ser en algunos blog de gurus de ciberseguridad. Su realidad: presupuesto, equipo, restricciones, legados.

Su posición relativa: Versus pares honestamente similares (no versus Google o Amazon). Benchmark significa "sé dónde estoy vs. alguien parecido a mí", no "confirme que me estoy quedando atrás."

Sus oportunidades reales: No las que suena bien en PPT, sino aquellas con ROI medible a 12-24 meses.

Sus fortalezas ignoradas: Porque la mayoría de PYMEs que respondieron hace 10 años a encuestas se asumía "inseguras por default". Muchas tienen prácticas brillantes a pesar de recursos limitados. Queremos documentar eso.

ACTO III: LA INVITACIÓN A LA HONESTIDAD RADICAL

Cómo Responder Esta Encuesta Sin Filtro Corporativo

Imaginemos un CISO respondiendo pregunta de escala 1-5 sobre gobernanza IA:

Respuesta automática (la que el board espera): "Selecciono 4 o 5. Suena bien. Protejo presupuesto próximo año."

Respuesta honesta (la que esta encuesta pide): "Tengo policy en borrador, el CISO (yo) reporta al CTO, no al CEO. No hemos mapeado contra MITRE ATLAS porque literalmente descubrimos hace 3 semanas que operamos 3 sistemas IA que ni sabíamos que existían. Así que: 2. Iniciado."

¿Por qué importa la honestidad radical?

Porque la segunda respuesta permite que la encuesta identifique:

- "¡Oye, hay 500+ CISOs en tu posición exacta—reporting a CTO, no C-level—y TODOS reportan gaps en gobernanza IA"
- "Eso no es un fallo tuyo. Es un problema sistémico de estructura corporativa."
- "Aquí hay 7 formas que otros CISOs encontraron para escalar sin alienar a CTO..."

Eso es valor.

La Escala Oculta de Respuestas

Por cada pregunta 1-5, existe una sexta opción invisible: el "miedo".

Miedo a admitir que:

- El SIEM nunca funciona realmente como promete
- El 30% de vulnerabilidades críticas nunca se parchean "porque el vendor no manda parche hasta Q3"
- La auditoría ISO 27001 pasamos porque el auditor simpatiza
- Tenemos Shadow AI *desenfrenado* y básicamente hemos decidido que vigilarlo consumiría tantos recursos que preferimos aceptar el riesgo

Esta encuesta dice: Ese miedo es comprensible. Y es información. Responda honestamente el "miedo" y verá que no está solo. Porque el otro 70% de respondentes con vuestro tamaño tiene exactamente el mismo miedo.

ACTO IV: LAS PREGUNTAS QUE IMPORTAN (Y POR QUÉ)

Más Allá de la Métrica

Notarán que la encuesta no pregunta: "¿Tiene CISO de tiempo completo?" sino "¿Reporta a CEO/C-level o a CTO?"

¿Por qué? Porque la presencia de CISO es necesaria pero insuficiente. Un CISO sin voz ejecutiva es un profeta en el desierto. Y queremos mapear ese desierto.

De igual forma, no preguntamos: "¿Tiene SIEM?" sino "¿Cuántas fuentes de datos tiene integradas? ¿Cuál es su MTTD real? ¿Cuál es su tasa de falsos positivos?"

¿Por qué? Porque "sí, tenemos SIEM" puede significar:

- SIEM empresarial con 80 fuentes correlacionadas e IA integrada que detecta en 15 minutos
- O SIEM piloto con 3 fuentes que genera 5,000 alertas diarias sin ninguna correlación real

Son dos categorías de seguridad radicalmente diferentes. La métrica borra esa diferencia.

Preguntas Irónicas Que Deberíamos Hacer (Pero No Nos Atrevemos)

En el espíritu de la honestidad radical:

- "¿Cuántos de sus incidentes detectados fueron reportados por usuario ('El correo de Pepe decía algo raro')?"
- "¿Ha pagado alguna vez ransomware porque el seguro lo cubría?"
- "¿Tiene datos tan sucios que ni se atreve a hacer RGPD audit?"
- "¿Su plan de respuesta a incidentes se basa en documentación o en 'llamar a ese consultor que conoce'?"

Las omitimos porque la encuesta debe ser profesional. Pero esas son las preguntas que *realmente* define postura seguridad.

Entonces las encryptamos en la madurez de gobernanza, en el SLA de remediación, en el porcentaje de personal capacitado.

ACTO V: TAXONOMÍA IRÓNICA DE RESPONDENTES

Los Tipos que Responderán Esta Encuesta

El CISO "Libro de Texto"

Perfil: Gran empresa, sector financiero, ama frameworks NIST, puede hablar 45 minutos sobre CMMC 2.0.

Respuesta probable: 4-5 en todo excepto una dimensión donde marca un honesto 3.

Reacción al informe: "Excelente, estamos en P75. ¿Pueden reportar esto al board?"

Valor real: Benchmarking válido, confirma que large-orgs con presupuesto tienen mayor madurez (predicción validada).

El CISO "Podrido de Frustración"

Perfil: Mediana empresa, presupuesto limitado, ha peleado 3 años por SIEM y board dice "¿para qué si tenemos antivirus?"

Respuesta probable: Honestidad radical. Muchos 2s, algunos 1s, pero notas aclaratorias explicando contexto.

Reacción al informe: "¿En serio hay 200+ CISOs como yo? ¿Que hacen para sobrevivir?"

Valor real: Hallazgo de "pequeños CISOs" que operan bajo presión. Generación de guía "Low-cost high-impact" directamente de pares.

El CISO "Ignorante Feliz"

Perfil: PYME, sin persona dedicada ciberseguridad real (alguien que "También hace seguridad"), MITRE ATLAS= ¿Qué es eso?

Respuesta probable: Marca "No sabe" en 40% preguntas, pero da respuestas en las que confía.

Reacción al informe: Probablemente no lo lea. Pero si lo hacen: shock al ver posición percentil (P5-P10).

Valor real: Identificación de brecha de conciencia en PYME. Indicador que necesita acción sector público (INCIBE).

El CISO "Consultor Buscando Datos"

Perfil: Consultor que puede usar esta encuesta para validar recomendaciones a cliente.

Respuesta probable: Responde varias veces, para diferentes clientes, posiblemente manipulando scores ligeramente.

Reacción al informe: Lo integra en propuesta comercial para cliente.

Valor real: Mínimo. Pero inevitable. La encuesta lo desalienta con anonimización.

El CISO "Académico Riguroso"

Perfil: Centro investigación, universidad, le interesa construir teoría ciberseguridad IA.

Respuesta probable: Responde exhaustivamente, incluye comentarios profundos en secciones abiertas.

Reacción al informe: Publica paper "Encuesta Benchmark Ciberseguridad España 2026: Hallazgos en gobernanza IA".

Valor real: Altísimo. Alimenta investigación, cita encuesta, crea loop de validación científica.

ACTO VI: LO QUE SUCEDERÁ DESPUÉS (La Verdad Incómoda)

Después de Responder, Tres Escenarios

Escenario A: El CISO Usa los Resultados Bien

- Obtiene reporte personalizado
- Identifica top-3 gaps
- Presenta al board con benchmarking
- Board aprueba presupuesto mejora
- 12 meses después: +8 puntos en escala madurez
- *Probabilidad: 25%*

Escenario B: El CISO Usa los Resultados Políticamente

- Obtiene reporte personalizado
- Lo integra en presentation "Estado Ciberseguridad"
- Lo cita selectivamente ("Estamos en P60, encima de mediana")
- Solicita presupuesto pequeño basado en enunciado "mejoras recomendadas"
- 12 meses después: +1 punto en escala madurez, pero el CISO tiene tracción política
- *Probabilidad: 50%*

Escenario C: El CISO No Usa los Resultados

- Responde encuesta porque le pareció interesante
- Recibe reporte
- Lo archiva en carpeta "Iniciativas Evaluadas"
- 12 meses después: nada cambió, pero CISO puede decir "Participé en estudio nacional"
- *Probabilidad: 25%*

La verdad irónica: Nuestra encuesta es *tan rigurosa* precisamente porque sabemos que la mayoría de respondentes no harán nada diferente.

El valor real está en los que sí lo hacen. Están en ese 25% de Escenario A + parte del 50% de Escenario B. Ese 35% de respondentes que usa datos para reducir fricción política, justificar inversión, compararse con pares.

Y eso es suficiente. Si 35% de 500+ CISOs acelera madurez ciberseguridad por esta encuesta = 175 organizaciones españolas más resilientes = cifras que importan.

ACTO VII: POR QUÉ HACEMOS ESTO (Y POR QUÉ IMPORTA)

La Proposición Central

España necesita mapeo actual de ciberseguridad IA porque:

5.
AIDA + AI Act + NIS2 convergen 2025-2026. Regulación no espera a que estemos listos. Hablamos de transposición NIS2 que ya debería haber ocurrido. Esto es acción correctiva: ¿Dónde estamos de facto?
6.
Shadow AI descontrolado. 80% empresas con ChatGPT/Copilot no autorizado. Tenemos que ver este fenómeno a escala nacional. Contarlo. Hacerlo visible.
7.
Agentes autónomos son realidad 2026, no 2030. Pero gobernanza para agentes casi no existe. La encuesta es uno de los primeros mapeos de "¿Quién tiene plan para esto?"
8.
Brecha defensiva real. 3,18/100 en uso de IA defensiva (ENISA). Eso es crisis. Necesitamos documentarla, hacerla pública, movilizar inversión pública en INCIBE.
9.
Talento en crisis. 78,6% ciudadanía demanda capacitación IA, pero oferta infinitesimal. Encuesta va identificar "¿Quién estamos perdiendo? ¿Dónde?"

AIDA + AI Act + NIS2 convergen 2025-2026. Regulación no espera a que estemos listos. Hablamos de transposición NIS2 que ya debería haber ocurrido. Esto es acción correctiva: ¿Dónde estamos *de facto*?

Shadow AI descontrolado. 80% empresas con ChatGPT/Copilot no autorizado. Tenemos que *ver* este fenómeno a escala nacional. Contarlo. Hacerlo visible.

Agentes autónomos son realidad 2026, no 2030. Pero gobernanza para agentes casi no existe. La encuesta es uno de los primeros mapeos de "¿Quién tiene plan para esto?"

Brecha defensiva real. 3,18/100 en uso de IA defensiva (ENISA). Eso es crisis. Necesitamos documentarla, hacerla pública, movilizar inversión pública en INCIBE.

Talento en crisis. 78,6% ciudadanía demanda capacitación IA, pero oferta infinitesimal. Encuesta va identificar "¿Quién estamos perdiendo? ¿Dónde?"

La Invitación Final

Cuando responda esta encuesta, no lo haga como si fuera audit donde alguien va a "detectar" inconsistencias y reportar.

Responda como si fuera conversación con 500+ pares honestamente interesados en la *realidad* de ciberseguridad IA en España 2026.

Porque eso es lo que es.

Y la invitación es: sea honesto. Especialmente en sus observaciones abiertas. Que es donde verdadera inteligencia sucede.

EPILOGO: EL PAPEL QUE CADA UNO JUEGA

Para CISOs (Especialmente PYMEs)

Esta encuesta existe para **crear legitimidad a su realidad**:

- No, no debería estar solo gestionando ciberseguridad para 500 personas
- Sí, es legítimo tener SIEM "casero" si no hay presupuesto profesional
- Sí, el training anual con tasa 35% clics phishing es mejor que sin training
- No, no es fracaso suyo si Shadow AI descontrolada: es fallo gobernanza corporativa

La encuesta lo dice. Numéricamente. A nivel nacional. Con benchmarking.

Úselo en conversaciones difíciles.

Para Boards y Ejecutivos

Cuando su CISO dice "Necesito 500k€ para SIEM empresarial porque scored 45/100 en madurez y pares en P75 score 72/100"—eso no es sales pitch.

Eso es información estructurada sobre posición competitiva + riesgo.

La encuesta existe para que eso sea verdad.

Para Reguladores (AESIA, CCN, INCIBE)

Los resultados de esta encuesta serán proveedor de inteligencia para:

- Calibración Ley ciberseguridad española
- Diseño programas capacitación INCIBE
- Prioridades supervisión AESIA
- Benchmarking UE (ENISA)

Es insumo político, científico, operacional.

Para Académicos y Futuros Investigadores

Primera encuesta formal que integra MITRE ATLAS + NIST CSF 2.0 + regulatorio europeo.

Base de datos anonimizada disponible para investigación posterior.

Contribuye a teoría ciberseguridad IA.

CIERRE: EL TONO CORRECTO

Esta encuesta ha sido diseñada con **tono propositivo y constructivo** porque:

No se trata de confirmar que todo está quebrado. (Lo sabemos.)

**Se trata de medir cómo está quebrado, proporcionar evidencia estructurada, e invitar acción con claridad sobre dónde empezar.*

Esa es forma de ser útil.

Así que adelante, caro responsable de ciberseguridad, auditor, estratega, ejecutivo.

Responda esta encuesta como si fuera conversación con 500 personas que entienden exactamente en qué mundo difícil opera la seguridad en 2026.

Porque eso es lo que es.

Y sus respuestas honestas crearán mapeo nacional que hace posible la mejora.

Escrito con ironía, respeto genuino, y la esperanza de que mil CISOs españoles encuentren en estos números suficiente claridad y legitimidad para tomar un paso mejor hacia seguridad.

Enero 2026